

Operating System Security

Assurance



Secure Operating Systems (One Definition)

A secure operating system's access enforcement satisfies the reference monitor concept.

The **reference monitor concept** defines the properties of any system that securely enforces a **mandatory protection system**, with three guarantees :

1. Complete mediation: the access enforcement mechanism mediates all security-sensitive operations
2. Tamperproof: the access enforcement mechanism & its protection system, can't be modified by bad processes
3. Verifiable: the access enforcement mechanism, including its protection system, must be completely assured (meaning it must be small enough for thorough analysis and testing).

Next Topic: a bit about Assurance

Basic meaning of “assurance”: whether capable, motivated people have beat up on the operating system enough.

- But, how do you define enough?



Assurance: Definition

Our estimate of the likelihood that (an operating system will not fail in a particular way.)

Can be based on a number of factors:

- ~~Process~~ used to develop the system
- Identity of the person or team who developed the system
- But neither of these are really enough...



Unfortunate reality: economics of incentive

Security is considered “secondary functionality”

- And thus often neglected in favour of the “primary functionality” (what the system’s software normally intends to do).

Assurance normally focuses on the implementation, as most real-life technical security failures are due to programming bugs (e.g., buffer overflows).

However, most assurance evaluations do not consider human-in-the-loop failures (e.g., poor usability of a security function).

- Important to keep in mind when viewing evaluations

Reflection Question

Can you think of a human-in-the-loop failure that could occur with the use of SELinux?

Example Human-in-the-loop failure

SELinux:

- Could verify that SELinux with the targeted policy has good access control.
- However, what if a system administrator decided to write and install a new policy that has many unnecessary allow rules (since they weren't sure which ones they needed).
 - E.g., allows unconfined_t to have access to kernel memory through the \proc filesystem?
- Such errors could happen due to the lack of usability in the process of creating new SELinux policies!

Evaluations

The process of assembling evidence that an operating system meets, or fails to meet, a prescribed assurance target.

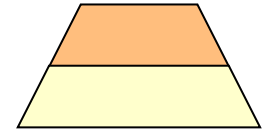
The Orange Book

“The Trusted Computer Systems Evaluation Criteria” (AKA “The Orange Book”).

An evaluation model used (1985-2000) at the NSA’s National Computer Security Center on computer security products proposed for US government use.



The Orange Book Levels



~~C1~~: Discretionary access control by groups of users. In effect, this is considered to be equal to no protection.

~~C2~~: Discretionary access control by single users.

(windy)

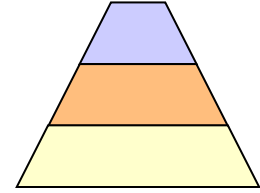
B1: Mandatory access control.

- All objects carry security labels, and the security policy is enforced independently of user actions.
- Labeling is enforced for all input information.

B
C
A
C

(SBLinux)

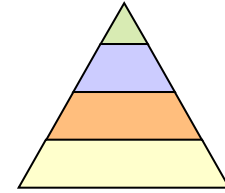
The Orange Book Levels



B2: Structured protection.

- As B1, but there must also be a formal model of the security policy that has been proven consistent with security goals.
- Tools must be provided for system administration and configuration management.

The Orange Book Levels



~~B3~~: Security domains.

- As B2, but the TCB must be minimal; it must mediate all access requests, be tamper-resistant, and be able to withstand formal analysis and testing.
- There must be real-time monitoring and alerting mechanisms, and structured techniques must be used in the implementation.

~~A1~~: Verification design.

- As B3, but formal techniques must be used to prove the equivalence between the TCB specification and the security policy level.

Discuss: What is the highest Orange Book level that Windows, UNIX, and Linux (without SELinux) could be evaluated to?

- C1
- C2
- B1
- B2
- B3
- A1

C2

Discuss: What is the highest Orange Book level that SELinux could be evaluated to?

- C1
- C2
- B1
- B2
- B3
- A1

B1

Reflection Question

What are some limitations of the Orange Book criteria?

Assurance: Common Criteria

- Started in 1993 by US, Canada, and European countries
- Attempt to identify a set of common criteria to evaluate information security
 - ISO standard as of 1999
 - A set of evaluation techniques used to vet technologies
 - ... and tell which ones were good or bad (more or less)
 - Allows consumers of goods and services to know whether advertised security is as good as claimed

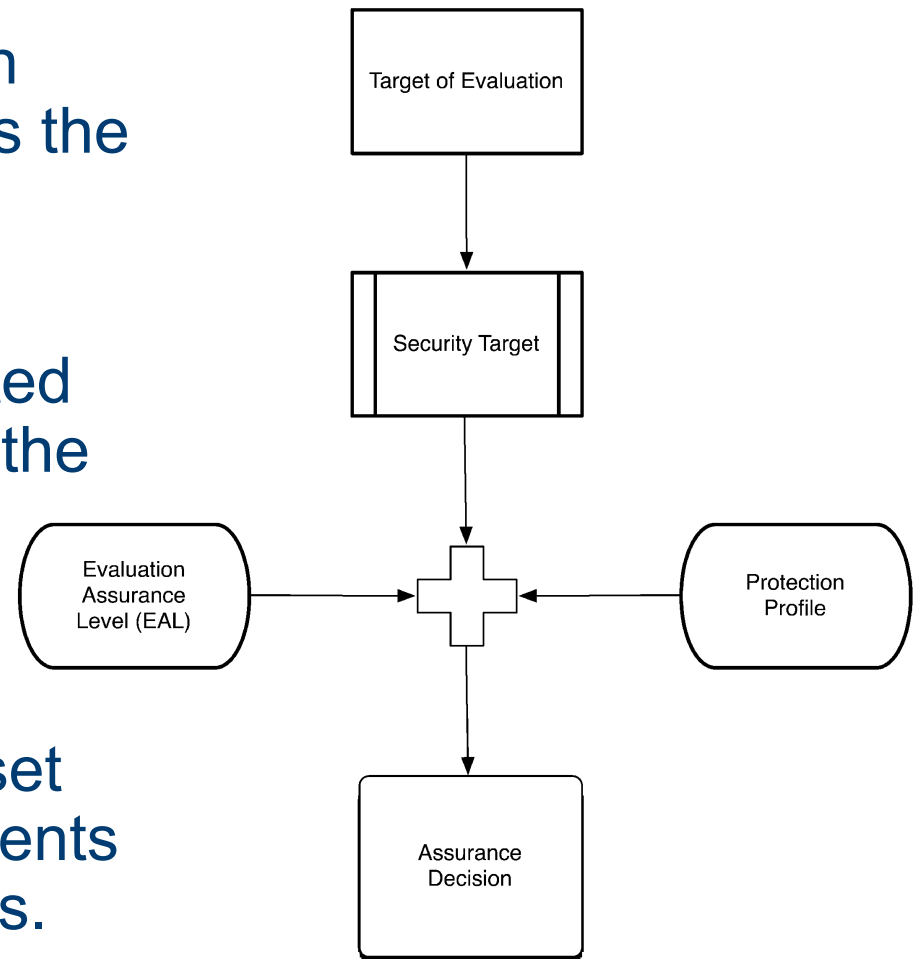


Common Criteria – The Process

Software is normally evaluated using a Protection Profile, which describes what security features the software will be evaluated for.

A target of evaluation is converted to a security target that defines the features and assurance being evaluated.

The assurance levels define a set of possible assurance requirements for the protection profile features.



Common Criteria Evaluation Assurance Levels (EALs)

EAL1: Functionally tested ✓

EAL2: Structurally tested ✓

- High-level design ✓

EAL3: Methodically tested and checked ✓

- High-level design motivates testing performed

EAL4: Methodically designed, tested, and reviewed

- Low-level design and vulnerability analysis

EAL5: Semi-formally designed and tested

- Rigorous development using semi-formal models

EAL6: Semi-formally verified design and tested

- Low-level design

 **EAL7:** Formally verified design and tested

EALs (+, or augmented)

Common Criteria EALs:

- '+' is shorthand for vendors to show evaluation was augmented to include extra assurance components. ✓
- Officially, + is replaced by the word augmented and usually with a list of codes to indicate the additional requirements.
- E.g., an OS is normally evaluated an additional set of requirements that are specific to operating systems.

OS-Related Protection Profiles

There are a number of operating system-related protection profiles.

FYI – many protection profiles can be found at <http://www.commoncriteriaportal.org/pps/index.cfm> and <https://www.commoncriteriaportal.org/pps/index.cfm?archived=1> (last accessed March 30, 2025).

Common Criteria in Practice

Many commercial operating systems have been assured to EAL4 in the past:

- Windows server 2003 & 2008, Windows XP and 7.
- Linux
- Linux with SELinux
- Solaris 10 with Trusted Extensions (EAL4+)

At least one specialized real-time operating system has a high EAL rating (EAL6+):

- Green Hills INTEGRITY.

What is limiting most commercial operating system's EAL?

More about formal methods

Formal methods provide a mathematical representation of the software and its behaviour and are required by EAL6 and EAL7. EAL5 requires some semi-formal verification.

There are two aspects of formal methods: the specification language that is used for formal expression, and the theorem prover that mathematically proves the completeness and correctness of the formal specification.

A formal specification is expressed within a formal system based upon mathematical concepts used to define semantics, syntax and rules of inference.

Examples of formal systems

ACL2 is an open-source formal system comprising a LISP-based specification language and a theorem prover.

- See <http://www.cs.utexas.edu/users/moore/acl2/> (last accessed March 27, 2025) for further information.

Isabelle is a theorem proving environment that allows mathematical formulae to be expressed in a formal language, and provides tools for proving those formulae

- See <http://www.cl.cam.ac.uk/Research/HVG/Isabelle/> (last accessed March 27, 2025) for additional information.

Reflection question: If a piece of software (or target of evaluation) has undergone and passed extensive vulnerability/penetration testing, does it mean it is formally verified?

Reflection Question: If someone tells you an operating system has EAL6, can you be sure it is a secure OS?

Summary Question

What is the relationship between assurance levels and the definition of a secure operating system given at the start of this lecture?

- Consider first the Common Criteria: which element of our definition does it relate to?
- Next consider the Orange Book: which element(s) does it relate to?